PropOS RBAC 权限矩阵（角色 × 端点级映射）

> 版本: v2.0
>
> 日期: 2026-04-13
>
> 依据: PRD v1.7（二、用户角色与权限矩阵）/ API*INVENTORY v1.7 / ARCH v1.2 / ROLE*EXPANSION_PLAN v1.0
>
> 用途: 后端 RBAC 中间件实现参考；权限审计基线
>
> 变更: v2.0 — 角色体系从 6 个扩展至 8 个（新增 `property_inspector` 、 `report_viewer` ； `frontline_staff` 更名为 `maintenance_staff` ）

一、角色定义

角色标识	中文名	定位	数据范围
`super_admin`	超级管理员	全系统控制	全部数据
`operations_manager`	运营管理层	业务决策 + 审批	管辖范围内数据
`leasing_specialist`	租务专员	合同 + 租客日常操作	管辖范围内数据
`finance_staff`	财务人员	财务收支 + 核销	全部财务数据
`maintenance_staff`	维修技工	工单接派 + 水电抄表	管辖范围内工单
`property_inspector`	楼管巡检员	巡检登记 + 资产查看	管辖楼栋/楼层
`report_viewer`	只读观察者	报表查看（投资人/审计）	全部只读数据
`sub_landlord`	二房东	自身子租赁填报	仅自身 `bound_contract_id` 范围

> 数据范围说明: 管辖范围内数据 指通过 `user_managed_scopes` 配置的楼栋/楼层范围；`sub_landlord` 的数据隔离在 Repository 层实现行级过滤； `report_viewer` 可查看全局只读数据但不可访问 PII（证件号/手机号）。
>
> **v1.0 → v2.0 变更说明:**
>
> - `frontline_staff` 已更名为 `maintenance_staff` ，仅保留工单操作 + 抄表权限
> - 新增 `property_inspector` （楼管巡检员）：资产查看 + 抄表 + 工单只读 + 租客基本信息
> - 新增 `report_viewer` （只读观察者）：全局 NOI/WALE/出租率报表 + 资产/合同摘要，零 write 权限

二、权限字符串清单

按模块分组，每个权限字符串对应一组可执行的端点。

权限字符串	含义	涉及模块
`org.read`	查看组织架构与管辖范围	公共
`org.manage`	增删改组织架构与管辖范围	公共
`assets.read`	查看楼栋/楼层/单元/改造/导出	M1
`assets.write`	增改楼栋/楼层/单元/导入/CAD上传	M1
`contracts.read`	查看租客/合同/递增/WALE/预警	M2
`contracts.write`	增改租客/合同/递增模板/终止/续签	M2
`deposit.read`	查看押金账户及流水	M2
`deposit.write`	押金收取/冻结/冲抵/退还	M2
`finance.read`	查看账单/收款/支出/NOI	M3
`finance.write`	生成账单/核销收款/录入支出/NOI预算	M3
`kpi.view`	查看自己的 KPI 得分	M3
`kpi.manage`	配置方案/查看全员/导出/审核申诉	M3
`kpi.appeal`	提交 KPI 申诉	M3
`meterReading.write`	录入水电抄表读数	M3
`turnoverReview.approve`	审核商铺营业额申报	M3
`workorders.read`	查看工单列表	M4
`workorders.write`	提报/派单/处理/验收工单	M4
`sublease.read`	查看子租赁数据与穿透看板	M5
`sublease.write`	内部录入/审核子租赁	M5
`sublease.portal`	二房东外部填报入口	M5
`alerts.read`	查看预警记录	M2
`alerts.write`	手工补发/处理预警	M2
`ops.read`	查看审计日志/任务日志/导入记录	公共
`ops.write`	手动触发任务/回滚导入	公共
`import.execute`	执行 Excel 批量导入	公共

三、角色 → 权限分配矩阵

✅ = 拥有　❌ = 无权限

权限字符串	super_admin	operations_manager	leasing_specialist	finance_staff	maintenance_staff	property_inspector	report_viewer	sub_landlord
`org.read`	✅	✅	✅	✅	❌	✅	✅	❌
`org.manage`	✅	✅	❌	❌	❌	❌	❌	❌
`assets.read`	✅	✅	✅	✅	❌	✅	✅	❌
`assets.write`	✅	✅	❌	❌	❌	❌	❌	❌
`contracts.read`	✅	✅	✅	✅	❌	✅[1]	✅[2]	❌
`contracts.write`	✅	✅	✅	❌	❌	❌	❌	❌
`deposit.read`	✅	✅	✅	✅	❌	❌	✅	❌
`deposit.write`	✅	✅	❌	✅	❌	❌	❌	❌
`finance.read`	✅	✅	✅[3]	✅	❌	❌	✅	❌
`finance.write`	✅	❌	❌	✅	❌	❌	❌	❌
`kpi.view`	✅	✅	✅	✅	✅	✅	✅	❌
`kpi.manage`	✅	✅	❌	❌	❌	❌	❌	❌
`kpi.appeal`	✅	✅	✅	✅	✅	✅	❌	❌
`meterReading.write`	✅	✅	✅	✅	✅	✅	❌	❌
`turnoverReview.approve`	✅	✅	❌	✅	❌	❌	❌	❌
`workorders.read`	✅	✅	✅	❌	✅	✅	❌	❌
`workorders.write`	✅	✅	❌	❌	✅	❌	❌	❌
`sublease.read`	✅	✅	✅	✅	❌	❌	✅	❌
`sublease.write`	✅	✅	✅	❌	❌	❌	❌	❌
`sublease.portal`	❌	❌	❌	❌	❌	❌	❌	✅
`alerts.read`	✅	✅	✅	✅	❌	❌	✅	❌
`alerts.write`	✅	✅	❌	❌	❌	❌	❌	❌

`ops.read`	✅	✅	❌	❌	❌	❌	❌	❌
`ops.write`	✅	❌	❌	❌	❌	❌	❌	❌
`import.execute`	✅	✅	✅[4]	✅[4]	❌	❌	❌	❌

注释:

1. `property_inspector` 的 `contracts.read` 限制为仅查看租客基本信息（姓名、房号），不可查看财务金额字段
2. `report_viewer` 的 `contracts.read` 限制为不可查看租客敏感信息（证件号、手机号等 PII）
3. `leasing_specialist` 的 `finance.read` 限制为仅查看与自身管辖合同关联的账单，不可查看全局 NOI 报表
4. `leasing_specialist` 和 `finance_staff` 仅可执行各自领域的导入（租务导入合同/单元，财务导入账单）

四、端点级权限映射

4.1 认证（公共端点）

端点	权限	说明
`POST /api/auth/login`	公共	无需 token
`POST /api/auth/refresh`	已登录	有效 refresh token
`POST /api/auth/logout`	已登录	—
`GET /api/auth/me`	已登录	—
`POST /api/auth/change-password`	已登录	—

4.2 用户管理

端点	权限	可执行角色
`GET /api/users`	super_admin 专属	super_admin
`GET /api/users/:id`	super_admin 专属	super_admin
`POST /api/users`	super_admin 专属	super_admin
`PATCH /api/users/:id`	super_admin 专属	super_admin
`PATCH /api/users/:id/status`	super_admin 专属	super_admin
`PATCH /api/users/:id/role`	super_admin 专属	super_admin
`PATCH /api/users/:id/department`	super_admin 专属	super_admin

4.3 组织架构（org.*）

端点	权限	可执行角色
`GET /api/departments`	org.read	SA, OM, LS, FS, PI, RV
`POST /api/departments`	org.manage	SA, OM
`PATCH /api/departments/:id`	org.manage	SA, OM
`DELETE /api/departments/:id`	org.manage	SA, OM
`GET /api/managed-scopes`	org.read	SA, OM, LS, FS, PI, RV
`PUT /api/managed-scopes`	org.manage	SA, OM

4.4 资产模块（assets.*）

端点	权限	可执行角色
`GET /api/buildings`	assets.read	SA, OM, LS, FS, PI, RV
`POST /api/buildings`	assets.write	SA, OM
`GET /api/buildings/:id`	assets.read	SA, OM, LS, FS, PI, RV
`PATCH /api/buildings/:id`	assets.write	SA, OM
`GET /api/floors`	assets.read	SA, OM, LS, FS, PI, RV
`POST /api/floors`	assets.write	SA, OM
`GET /api/floors/:id`	assets.read	SA, OM, LS, FS, PI, RV
`POST /api/floors/:id/cad`	assets.write	SA, OM
`GET /api/floors/:id/heatmap`	assets.read	SA, OM, LS, FS, PI, RV
`GET /api/floors/:id/plans`	assets.read	SA, OM, LS, FS, PI, RV
`PATCH /api/floor-plans/:id/set-current`	assets.write	SA, OM
`GET /api/units`	assets.read	SA, OM, LS, FS, PI, RV
`POST /api/units`	assets.write	SA, OM
`GET /api/units/:id`	assets.read	SA, OM, LS, FS, PI, RV
`PATCH /api/units/:id`	assets.write	SA, OM
`POST /api/units/import`	assets.write + import.execute	SA, OM
`GET /api/renovations`	assets.read	SA, OM, LS, FS, PI, RV
`POST /api/renovations`	assets.write	SA, OM
`GET /api/renovations/:id`	assets.read	SA, OM, LS, FS, PI, RV
`PATCH /api/renovations/:id`	assets.write	SA, OM
`POST /api/renovations/:id/photos`	assets.write	SA, OM
`GET /api/units/export`	assets.read	SA, OM, LS, FS, PI, RV
`GET /api/assets/overview`	assets.read	SA, OM, LS, FS, PI, RV

4.5 租务与合同（contracts.*）

端点	权限	可执行角色
`GET /api/tenants`	contracts.read	SA, OM, LS, FS, PI[1], RV[2]
`POST /api/tenants`	contracts.write	SA, OM, LS
`GET /api/tenants/:id`	contracts.read	SA, OM, LS, FS, PI[1], RV[2]
`PATCH /api/tenants/:id`	contracts.write	SA, OM, LS
`GET /api/contracts`	contracts.read	SA, OM, LS, FS, RV[2]
`POST /api/contracts`	contracts.write	SA, OM, LS
`GET /api/contracts/:id`	contracts.read	SA, OM, LS, FS, RV[2]
`PATCH /api/contracts/:id`	contracts.write	SA, OM, LS
`POST /api/contracts/:id/sign`	contracts.write	SA, OM, LS
`POST /api/contracts/:id/activate`	contracts.write	SA, OM, LS
`POST /api/contracts/:id/renew`	contracts.write	SA, OM, LS
`POST /api/contracts/:id/terminate`	contracts.write	SA, OM, LS
`POST /api/contracts/import`	contracts.write + import.execute	SA, OM, LS
`GET /api/contracts/:id/attachments`	contracts.read	SA, OM, LS, FS
`POST /api/contracts/:id/attachments`	contracts.write	SA, OM, LS
`GET /api/escalation-templates`	contracts.read	SA, OM, LS
`POST /api/escalation-templates`	contracts.write	SA, OM, LS
`PATCH /api/escalation-templates/:id`	contracts.write	SA, OM, LS
`DELETE /api/escalation-templates/:id`	contracts.write	SA, OM
`GET /api/wale/current`	contracts.read	SA, OM, LS, FS, RV
`GET /api/wale/trend`	contracts.read	SA, OM, LS, FS, RV
`GET /api/wale/waterfall`	contracts.read	SA, OM, LS, FS, RV
`GET /api/alerts`	alerts.read	SA, OM, LS, FS, RV
`POST /api/alerts/:id/resend`	alerts.write	SA, OM
`PATCH /api/alerts/:id/dismiss`	alerts.write	SA, OM

4.6 押金（deposit.*）

端点	权限	可执行角色
`GET /api/deposits`	deposit.read	SA, OM, LS, FS
`GET /api/deposits/:id`	deposit.read	SA, OM, LS, FS
`POST /api/deposits`	deposit.write	SA, OM, FS
`POST /api/deposits/:id/freeze`	deposit.write	SA, OM, FS
`POST /api/deposits/:id/credit`	deposit.write	SA, OM, FS
`POST /api/deposits/:id/refund`	deposit.write	SA, OM, FS
`POST /api/deposits/:id/transfer`	deposit.write	SA, OM, FS
`GET /api/deposits/:id/transactions`	deposit.read	SA, OM, LS, FS

4.7 财务（finance.*）

端点	权限	可执行角色
`GET /api/invoices`	finance.read	SA, OM, LS[3], FS, RV
`POST /api/invoices/generate`	finance.write	SA, FS
`PATCH /api/invoices/:id`	finance.write	SA, FS
`POST /api/invoices/:id/cancel`	finance.write	SA, FS
`GET /api/invoices/export`	finance.read	SA, OM, FS
`GET /api/payments`	finance.read	SA, OM, FS, RV
`POST /api/payments`	finance.write	SA, FS
`POST /api/payments/:id/allocate`	finance.write	SA, FS
`GET /api/expenses`	finance.read	SA, OM, FS, RV
`POST /api/expenses`	finance.write	SA, FS
`PATCH /api/expenses/:id`	finance.write	SA, FS
`DELETE /api/expenses/:id`	finance.write	SA, FS
`GET /api/noi/current`	finance.read	SA, OM, RV
`GET /api/noi/trend`	finance.read	SA, OM, RV
`GET /api/noi/breakdown`	finance.read	SA, OM, RV
`GET /api/noi/budget`	finance.read	SA, OM, FS, RV
`PUT /api/noi/budget`	finance.write	SA, FS

4.8 KPI（kpi.*）

端点	权限	可执行角色
`GET /api/kpi/metrics`	kpi.view	SA, OM, LS, FS, MS, PI, RV
`GET /api/kpi/schemes`	kpi.manage	SA, OM
`POST /api/kpi/schemes`	kpi.manage	SA, OM
`PATCH /api/kpi/schemes/:id`	kpi.manage	SA, OM
`GET /api/kpi/schemes/:id`	kpi.manage	SA, OM
`POST /api/kpi/schemes/:id/freeze`	kpi.manage	SA, OM
`GET /api/kpi/snapshots`	kpi.view ∪ kpi.manage	SA, OM（全员）; LS, FS, MS, PI（仅自己）; RV（全员只读）
`GET /api/kpi/snapshots/:id`	kpi.view ∪ kpi.manage	SA, OM（全员）; LS, FS, MS, PI（仅自己）; RV（全员只读）
`POST /api/kpi/snapshots/:id/recalculate`	kpi.manage	SA, OM
`GET /api/kpi/rankings`	kpi.manage	SA, OM
`GET /api/kpi/export`	kpi.manage	SA, OM
`POST /api/kpi/appeals`	kpi.appeal	SA, OM, LS, FS, MS, PI（仅自己的快照）
`PATCH /api/kpi/appeals/:id/review`	kpi.manage	SA, OM
`GET /api/kpi/appeals`	kpi.manage ∪ kpi.appeal	SA, OM（全部）; 其他（仅自己）

4.9 水电抄表与营业额

端点	权限	可执行角色
`GET /api/meter-readings`	finance.read	SA, OM, LS, FS
`POST /api/meter-readings`	meterReading.write	SA, OM, LS, FS, MS, PI
`GET /api/turnover-reports`	finance.read	SA, OM, FS
`POST /api/turnover-reports`	finance.write	SA, FS
`PATCH /api/turnover-reports/:id/review`	turnoverReview.approve	SA, OM, FS

4.10 工单（workorders.*）

端点	权限	可执行角色
`GET /api/work-orders`	workorders.read	SA, OM, LS, MS, PI
`POST /api/work-orders`	workorders.write	SA, OM, MS
`GET /api/work-orders/:id`	workorders.read	SA, OM, LS, MS, PI
`PATCH /api/work-orders/:id`	workorders.write	SA, OM, MS
`POST /api/work-orders/:id/assign`	workorders.write	SA, OM
`POST /api/work-orders/:id/complete`	workorders.write	SA, OM, MS
`POST /api/work-orders/:id/inspect`	workorders.write	SA, OM
`POST /api/work-orders/:id/photos`	workorders.write	SA, OM, MS
`GET /api/suppliers`	workorders.read	SA, OM
`POST /api/suppliers`	workorders.write	SA, OM
`PATCH /api/suppliers/:id`	workorders.write	SA, OM

4.11 二房东穿透（sublease.*）

端点	权限	可执行角色
`GET /api/subleases`	sublease.read	SA, OM, LS, FS, RV
`POST /api/subleases`	sublease.write	SA, OM, LS
`PATCH /api/subleases/:id`	sublease.write	SA, OM, LS
`PATCH /api/subleases/:id/review`	sublease.write	SA, OM, LS
`GET /api/subleases/dashboard`	sublease.read	SA, OM, RV
`GET /api/subleases/import-template`	sublease.write	SA, OM, LS
`POST /api/subleases/import`	sublease.write + import.execute	SA, OM, LS
二房东外部端点		
`GET /api/portal/subleases`	sublease.portal	SL
`POST /api/portal/subleases`	sublease.portal	SL
`PATCH /api/portal/subleases/:id`	sublease.portal	SL
`POST /api/portal/subleases/import`	sublease.portal	SL
`GET /api/portal/units`	sublease.portal	SL

4.12 导入与运维（ops.* / import.*）

端点	权限	可执行角色
`GET /api/import-batches`	ops.read	SA, OM
`POST /api/import-batches/:id/rollback`	ops.write	SA
`GET /api/audit-logs`	ops.read	SA, OM
`GET /api/job-logs`	ops.read	SA, OM
`POST /api/jobs/:name/trigger`	ops.write	SA

4.13 文件服务

端点	权限	可执行角色
`GET /api/files/*`	已登录（按上层资源权限过滤）	所有已登录用户
`POST /api/files/upload`	由上层业务端点权限控制	—

五、角色缩写对照

缩写	角色
SA	super_admin
OM	operations_manager
LS	leasing_specialist
FS	finance_staff
MS	maintenance_staff
PI	property_inspector
RV	report_viewer
SL	sub_landlord

六、RBAC 中间件实现要点

1. 权限解析: `GET /api/auth/me` 返回 `permissions[]` 数组，中间件将当前请求路径 + 方法映射到所需权限字符串

2. **复合权限**: 部分端点需要多权限（如导入需 `assets.write` + `import.execute`），中间件用 AND 逻辑校验
3. **行级过滤**: `sub_landlord` 角色在 Repository 层注入 `WHERE master_contract_id = :bound_contract_id` 条件
4. **数据范围过滤**: 非 `super_admin` / `report_viewer` 角色按 `user_managed_scopes` 配置过滤数据，优先级：个人范围 > 部门默认范围；`report_viewer` 全局只读无需范围限制
5. **审计日志**: 所有写操作（POST/PATCH/PUT/DELETE）触发 `audit_logs` 记录
6. **二房东端点隔离**: `/api/portal/*` 端点独立路由组，仅 `sub_landlord` 可访问，其他角色 403

七、前端页面映射（v2.1 新增）

> 详细的页面-角色可见性矩阵请参见 `docs/frontend/PAGE_ROLE_VISIBILITY_MATRIX.md`。

7.1 API 权限 → 前端页面路由对照

API 权限	前端路由（不可达时重定向`/`）
`assets.read`	`/assets`, `/assets/:id`, `/assets/:id/:floor`, `/assets/:id/:floor/:unitId`
`contracts.read`	`/contracts`, `/contracts/:id`, `/tenants/:id`
`contracts.write`	`/contracts/escalation-templates`
`finance.read`	`/finance`, `/finance/invoices`, `/finance/payments`, `/finance/revenue-detail`, `/finance/turnover-reports`, `/finance/deposits`
`finance.write`	`/finance/noi-budget`, `/finance/expenses/new`, `/finance/invoices/:id/pay`
`workorders.read`	`/work-orders`, `/work-orders/:id`, `/work-orders/cost-report`（需 `finance.read`）
`sublease.read`	`/subleases`, `/subleases/analytics`
`kpi.view`	`/finance/kpi`
`kpi.manage`	`/finance/kpi/schemes`, `/finance/kpi/schemes/*`
`meterReading.write`	`/finance/meter-readings`, `/finance/meter-readings/new`

7.2 前端数据分级与整区域隐藏

前端采用整区域隐藏策略（不使用 `***` 脱敏），分 4 个数据级别：

级别	内容	不可见角色	前端 helper
L1 公开	楼栋名/单元号/状态	—	无需门控

L2 业务	出租率%/合同数量/KPI 得分	MS (仅工单域)	`hasPermission(role, 'assets.read')`
L3 财务	¥ 金额/NOI/收款率	PI, MS	`canViewFinancialData(role)`
L4 敏感	证件号/手机号	PI, RV, MS	`canViewPII(role)`